

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Domain 6 Exam Tips and Key Takeaways

1. Learning Objectives

By the end of this lecture, you will be able to:

- Apply the correct legal framework to jurisdiction-conflict scenarios involving GDPR, HIPAA, FERPA, PIPEDA, and India's DPDP.
- Distinguish between data roles (controller, processor, owner, custodian, steward) and identify which role applies in cloud-specific scenarios.
- Correctly classify SOC 1, SOC 2, SOC 3, and ISAE 3402 reports and identify when each is the appropriate audit evidence.
- Identify and avoid the five most common Domain 6 exam traps, including conflating SLAs with security guarantees and misreading supply chain scope.
- Apply the principle that cloud migration transfers operational tasks but does not transfer legal obligations to answer accountability questions.

2. Introduction: Thirteen Percent of the Exam, One Governing Principle

Domain 6 carries thirteen percent of the CCSP exam weight — roughly thirteen to twenty questions in a full adaptive exam, depending on how the test engine calibrates to your performance. That weighting reflects a deliberate judgment by ISC2 that security practitioners operating in cloud environments must understand not only the technical controls but the legal and regulatory architecture those controls must satisfy. A technically excellent cloud deployment that fails to account for applicable privacy regulations, audit obligations, or contractual accountability is not a secure deployment — it is a liability waiting to be triggered.

The good news is that Domain 6 is highly structured. It tests whether you know which framework applies, which role carries which accountability, and which contractual or audit mechanism addresses which type of gap. Unlike Domain 1 or Domain 3, where understanding design trade-offs requires nuanced technical judgment, Domain 6 questions tend to have clear correct answers once you know the frameworks. The challenge is knowing them precisely enough to navigate distractors that sound plausible but assign the wrong mechanism to the right scenario.

This guide consolidates the entire domain around the single principle that organises all of it: moving to the cloud transfers operational tasks but does not transfer legal obligations. The customer may no longer operate the data centre, but the customer remains accountable for the data, the compliance posture, and the audit trail. Every contract, every audit report, every insurance clause, and every regulatory framework in this domain exists to operationalise that

principle. Once you have internalised it, the domain becomes a matter of knowing which tool does what job.

3. Domain 6 Framework: Key Topic Areas Consolidated

3a. Legal Frameworks and Jurisdictional Conflict

The CCSP exam frequently presents scenarios where two or more regulatory frameworks apply simultaneously. A cloud customer in the United States engaging a provider with infrastructure in Germany may face GDPR (because the data includes EU personal data), HIPAA (because the data includes protected health information), and potentially CCPA (because California residents are among the data subjects). These frameworks do not always align. GDPR requires seventy-two-hour breach notification; HIPAA requires sixty days. GDPR provides a right to erasure; HIPAA does not grant equivalent data subject rights.

The governing principle for jurisdictional conflict: the more restrictive requirement governs. Where two frameworks impose conflicting obligations, the organisation must satisfy both, which in practice means meeting the higher standard. Organisations must assess legal risk before deploying data across regions — not after a regulatory inquiry has already been opened.

An additional complexity: some regulations follow the data subject's location (GDPR applies to EU residents' data regardless of where the processor is located). Others follow the regulated entity's location (HIPAA applies to covered entities and business associates in the US healthcare sector). Knowing which jurisdiction each regulation follows is tested directly on the exam.

3b. Privacy Regulation Scope and Unique Requirements

Each regulation has a specific geography, data type, and protected population. Exam questions will describe a scenario and ask which regulation applies or what it requires. The most commonly tested regulations and their key characteristics:

GDPR covers personal data of individuals in the European Union, applies regardless of where the processing organisation is located, gives data subjects rights including erasure and portability, requires explicit lawful basis for processing, and imposes breach notification within seventy-two hours to the supervisory authority.

HIPAA protects protected health information in the United States, applies to covered entities (healthcare providers, insurers) and their business associates, requires administrative, physical, and technical safeguards, and allows up to sixty days for breach notification to affected individuals.

FERPA protects student educational records in the United States, gives parents (or eligible students aged 18+) rights to access and correct records, and restricts disclosure without consent. Unlike GDPR, it does not impose explicit security control requirements — it is a data access and disclosure framework.

PIPEDA governs personal information collected by private-sector organisations in Canada for commercial purposes, requires meaningful consent and access rights, and has been increasingly supplemented by provincial legislation in Quebec and elsewhere.

India's Digital Personal Data Protection Act (DPDPA), enacted in 2023, introduces consent-based processing requirements, data fiduciary obligations (similar to GDPR controller obligations), rights to correction and erasure, and significant penalties for non-compliance. The exam now expects familiarity with DPDPA as part of the global regulatory landscape.

3c. Data Roles — A Reliable Source of Exam Questions

Data roles are among the most frequently tested concepts in Domain 6. The exam expects precision: each role has a distinct function, and confusing them in a scenario question typically produces an incorrect answer.

The controller decides the purpose and means of processing personal data. The controller is legally accountable for the data under GDPR and comparable frameworks, even when processing is delegated to a processor. In a cloud scenario, the customer organisation that defines why personal data is being processed and how it is used is the controller.

The processor handles personal data on the controller's behalf, under a data processing agreement that defines permissible processing activities. In a cloud scenario, the cloud provider acting on customer instructions is the processor. Critically, the processor does not decide the purpose of processing — that remains with the controller.

The data owner has ultimate accountability for the data asset within the organisation. In practice, this is typically a business unit leader or data governance role rather than a technical function. The owner defines what data exists, what protection it requires, and who may access it.

The data custodian manages the storage and safekeeping of data on behalf of the owner. In a cloud context, the provider may act as custodian for some data types. The key distinction from processor: a custodian stores data without necessarily processing it for a defined business purpose.

The data steward handles day-to-day operational data governance — maintaining data quality, enforcing classification policies, and ensuring that data handling practices align with the owner's requirements. This is an operational role, not a legal accountability role.

Exam trap: Do not confuse custodian with processor. A cloud backup service storing encrypted archives acts as custodian — it holds data without processing it for a business purpose. A cloud analytics service ingesting that data to produce business intelligence reports acts as processor — it is actively handling personal data as part of service delivery.

3d. Audit Report Types

SOC 1 assesses controls relevant to user organisation's internal control over financial reporting. It is the appropriate report when the question involves SOX compliance, financial

data processing, or when a cloud provider hosts systems that affect an organisation's financial statements. Issued under SSAE 18 in the United States.

SOC 2 assesses controls across the five Trust Services Criteria: security, availability, processing integrity, confidentiality, and privacy. It is the primary market standard for general security assurance in commercial cloud engagements. A Type II report covers a defined operating period (typically six to twelve months), demonstrating that controls were operating effectively throughout — not just designed correctly.

SOC 3 is a publicly distributable summary of SOC 2 findings. It contains less detail and is designed for general audience consumption, not for detailed audit evidence. It does not satisfy regulatory requirements that require the full SOC 2 report.

ISAE 3402 is the international equivalent of SSAE 18 and is used outside the United States for the same purpose — assessing service organisation controls relevant to user organisation financial reporting. When a non-US provider needs to demonstrate SOC 1-equivalent assurance, the report is issued under ISAE 3402.

Gap analysis: a pre-certification assessment identifying the difference between current controls and the requirements of a target framework. A gap analysis precedes certification but is not itself a certification. Exam questions sometimes present gap analysis as a substitute for a SOC report — it is not.

3e. Contract Components

The Master Service Agreement governs the overall commercial relationship between the customer and provider. It typically covers commercial terms, liability caps, dispute resolution, and general obligations.

The Statement of Work defines the specific scope of a particular engagement within the MSA. For professional services or customisation work, the SOW specifies deliverables, timelines, and acceptance criteria.

The Service Level Agreement defines measurable performance commitments: availability targets, response times, incident resolution windows. An SLA is a performance document. It does not define security obligations, audit rights, or data handling requirements.

Security obligations are captured in data processing agreements (for personal data under GDPR and similar frameworks), security annexes, or separate contractual addenda. The right-to-audit clause, breach notification requirements, and sub-processor obligations belong here, not in the SLA.

The data processing agreement is the specific instrument required under GDPR Article 28 when a controller engages a processor. It must define the subject matter, duration, nature, and purpose of processing; the categories of data; the obligations and rights of the controller; and sub-processor management requirements.

4. Audit Report Types at a Glance

Report	Standard	What It Assesses	When to Use It	Public?
SOC 1	SSAE 18 (US) / ISAE 3402 (international)	Controls relevant to user organisation's financial reporting (ICFR)	SOX compliance; financial systems hosted by third parties	No — restricted to customers and auditors
SOC 2 Type I	SSAE 18	Design of controls against Trust Services Criteria at a point in time	Initial vendor onboarding; design-only assessment	No — restricted to customers and auditors
SOC 2 Type II	SSAE 18	Operating effectiveness of controls over a defined period	Primary market standard for ongoing cloud security assurance	No — restricted to customers and auditors
SOC 3	SSAE 18	Summary of SOC 2 findings	Public-facing trust demonstration; marketing use	Yes — publicly distributable
ISAE 3402	IAASB	International equivalent of SOC 1	SOX-equivalent assurance outside the United States	No — restricted to customers and auditors
Gap Analysis	N/A	Difference between current controls and target framework	Pre-certification assessment; remediation planning	Internal only

5. Privacy Regulations — Jurisdiction and Scope Summary

Regulation	Geography	Data Type	Key Unique Feature	Breach Notification Window
GDPR	EU (applies globally to EU resident data)	Personal data of EU residents	Right to erasure and portability; 72-hr notification to supervisory authority	72 hours to supervisory authority
HIPAA	United States	Protected health information (PHI)	Covers covered entities AND business associates	60 days to individuals

FERPA	United States	Student educational records	Disclosure restriction framework (not a security control standard)	No explicit timeframe defined
PIPEDA	Canada	Personal info collected commercially	Meaningful consent requirement; provincial supplements	As soon as feasible (if real risk of harm)
DPDPA	India	Personal data of Indian residents	Consent-based processing; Data Fiduciary obligations	As soon as practicable (24–72 hrs under draft rules)

6. Case Study: The Capital One Breach and the Controller Accountability Principle

Case Study: In 2019, a former cloud provider employee exploited a misconfigured web application firewall to access approximately 100 million Capital One customer records stored in the cloud. Capital One was the data controller — it had defined the purpose and means of storing customer financial data. The cloud provider operated the infrastructure. When regulatory enforcement followed, Capital One bore the primary accountability: it was fined and required to invest in remediation, not the cloud provider. The case is a practical illustration of the principle that moving data to the cloud transfers the operational burden of managing infrastructure but does not transfer the legal accountability for protecting data. Capital One retained controller status and therefore retained regulatory exposure, regardless of which party's infrastructure was involved in the incident.

The Capital One case also illustrated a secondary principle relevant to Domain 6: shared responsibility models define what each party is responsible for technically, but they do not divide legal accountability. The provider's responsibility for the infrastructure layer does not insulate the controller from accountability for misconfigured application-layer controls. Understanding where the shared responsibility boundary falls — and what controls the customer must implement above that boundary — is part of cloud security governance, not just a technical design question.

7. Memory Anchor

Think of it this way: Domain 6 is a job description for everyone involved in cloud data. The controller is the client who hired the firm and is accountable for the outcome. The processor is the contractor doing the work under instructions. The custodian is the filing clerk holding the documents. The steward is the office manager keeping the files organised day to day. The owner is the company that owns the intellectual property. When something goes wrong, regulators go to the

controller first — not the contractor — because the controller hired the contractor, set the terms, and signed the data processing agreement. Cloud migration is outsourcing. Outsourcing is not accountability transfer.

8. Domain 6 Exam Traps — Know These Before Test Day

Trap 1 — Confusing legal accountability with operational responsibility: Moving operations to the cloud does not transfer legal accountability. The controller remains accountable under GDPR. The covered entity remains accountable under HIPAA. When exam scenarios describe a cloud provider causing a breach, the customer organisation still bears regulatory exposure if it failed to exercise adequate oversight.

Trap 2 — Treating an SLA as a security guarantee: An SLA defines performance metrics and remedies for underperformance (typically service credits or termination rights). It does not guarantee security outcomes. Security obligations are in the data processing agreement, the security annex, and the right-to-audit clause. Selecting an answer that says 'the SLA should have been stronger' when the question is about a security gap is almost always wrong.

Trap 3 — Confusing SOC 1 with SOC 2: SOC 1 = financial reporting controls (SOX-relevant). SOC 2 = Trust Services Criteria (security assurance). The exam often presents a scenario requiring SOX compliance and offers SOC 2 as a distractor. SOC 2 does not satisfy SOX requirements. Similarly, SOC 3 is a public summary of SOC 2 — it does not provide the detailed evidence either type requires.

Trap 4 — Assuming supply chain risk stops at the direct vendor: The exam will describe breaches originating from sub-vendors (hardware manufacturers, software update vendors, third-tier providers). The correct answers acknowledge that supply chain risk is multilateral and that ISO/IEC 27036 addresses multi-tier oversight. Answers that limit responsibility to the direct provider are wrong.

Trap 5 — Confusing custodian with processor: A custodian stores data. A processor actively handles personal data as part of service delivery for a defined business purpose. Cloud backup services are often custodians. Cloud analytics or payment processing services are typically processors. The distinction matters for GDPR because only processors must sign a data processing agreement under Article 28.

9. Key Terms Glossary

Controller: The entity that determines the purpose and means of processing personal data; legally accountable under GDPR and comparable frameworks.

Processor: An entity that processes personal data on behalf of the controller under a data processing agreement, acting only on controller instructions.

Data owner: The individual or organisational role with ultimate accountability for a data asset; defines classification and permissible use.

Data custodian: The role responsible for physical or technical storage and safekeeping of data on behalf of the owner; does not determine processing purpose.

Data steward: The operational governance role ensuring day-to-day data quality, classification enforcement, and policy compliance.

SOC 1: A report assessing service organisation controls relevant to user organisations' internal control over financial reporting; issued under SSAE 18 or ISAE 3402.

SOC 2 Type II: A report assessing operating effectiveness of controls against the Trust Services Criteria over a defined period; the primary cloud security assurance standard.

ISAE 3402: The international assurance standard equivalent to SSAE 18 SOC 1; used outside the United States for financial reporting control assessments.

Master Service Agreement (MSA): The overarching commercial contract defining the overall terms of the customer-provider relationship.

Data Processing Agreement (DPA): The contractual instrument required under GDPR Article 28 between a controller and processor, defining processing scope and security obligations.

DPDPA: India's Digital Personal Data Protection Act; introduces consent-based processing requirements and Data Fiduciary obligations for organisations handling Indian residents' personal data.

Gap analysis: An assessment identifying the difference between current security controls and the requirements of a target framework; precedes but does not substitute for formal certification.

10. Quick Revision Checklist

- ☐ I know that the more restrictive requirement governs when two regulatory frameworks impose conflicting obligations.
- ☐ I can name the geographic scope, data type, and one unique feature for GDPR, HIPAA, FERPA, PIPEDA, and DPDPA.
- ☐ I can correctly identify controller, processor, owner, custodian, and steward in a cloud scenario.
- ☐ I will not confuse custodian (stores data) with processor (handles data for a defined business purpose).
- ☐ I know that SOC 1 is the SOX-relevant report and SOC 2 assesses Trust Services Criteria.
- ☐ I can distinguish SOC 2 Type I (design only) from Type II (operating effectiveness over a period).
- ☐ I know ISAE 3402 is the international equivalent of SSAE 18 SOC 1.
- ☐ I understand that an SLA is a performance document, not a security guarantee.

- ☐ I know that supply chain risk in ISO/IEC 27036 extends beyond the direct provider to sub-vendor tiers.
- ☐ I can state the governing principle: cloud migration transfers operational tasks but not legal obligations.

11. Practice Questions

Question 1 (Scenario-Based)

Scenario: A US-based healthcare analytics company collects patient records from hospitals in three EU member states and processes them in a US cloud environment. The company's legal team identifies obligations under both HIPAA and GDPR. A breach occurs that potentially affects records of EU patients. GDPR requires notification to the supervisory authority within 72 hours. HIPAA allows up to 60 days for notification to affected individuals. The company asks its compliance officer which timeline governs. What is the correct answer?

A. The HIPAA timeline governs because the company is a US entity subject to US law.

→ Incorrect. GDPR applies to any organisation processing personal data of EU residents, regardless of where that organisation is located. The company cannot avoid GDPR notification obligations by invoking US jurisdiction. When two frameworks apply, both must be satisfied — which means the stricter timeline governs the determination of which obligation to fulfil first.

B. Both timelines govern: the 72-hour GDPR notification to the supervisory authority must be met for EU patient data, while the 60-day HIPAA notification to individuals must also be met. The more restrictive (72-hour) requirement governs first.

→ Correct. This scenario illustrates the governing principle for jurisdictional conflicts: both frameworks apply, and both must be satisfied. The organisation must notify the relevant EU supervisory authority within 72 hours (GDPR) and must also notify affected individuals within 60 days (HIPAA). In practice, the 72-hour obligation takes priority and must be acted on immediately. Failing to meet the GDPR timeline while complying only with HIPAA would expose the company to EU regulatory enforcement.

C. Neither framework applies because the breach occurred in the US cloud environment, which is subject to US law only.

→ Incorrect. The location of the breach (the cloud environment) does not determine which law applies. GDPR follows the data subject — it applies because the individuals whose data was compromised are EU residents. HIPAA follows the regulated entity and data type — it applies because the data is PHI held by a covered entity or business associate.

D. The company should apply the less restrictive timeline to minimise operational disruption from premature notification.

→ Incorrect. When two regulatory frameworks impose conflicting timelines, the more restrictive requirement governs. Applying the less restrictive timeline to reduce operational

burden would leave the company in violation of GDPR, exposing it to supervisory authority enforcement and potential fines.

Question 2 (Scenario-Based)

Scenario: A financial technology company delegates the processing of retail payment data to a cloud provider under a data processing agreement. The cloud provider uses a sub-contractor to perform real-time fraud scoring on transaction data. A data subject submits a right-of-access request to the fintech company. The fintech's operations team argues that the cloud provider is the controller for fraud scoring data because it operates the scoring engine. Is this correct, and what is the fintech's obligation?

A. Correct — the cloud provider becomes the controller for fraud scoring because it determines the algorithmic means of processing.

→ Incorrect. Operating a system and determining the means of processing are not the same thing. The fintech defined the business purpose (fraud prevention for its customers) and engaged the provider to execute it. Deciding which algorithm to use is implementation detail, not determination of processing purpose. The fintech remains the controller.

B. Incorrect — the fintech remains the controller because it defined the purpose of processing (fraud prevention); the provider is the processor operating under instructions, and the fintech must respond to the access request including data processed by sub-contractors on its behalf.

→ Correct. Under GDPR, the controller is the entity that determines the purpose and means of processing. The fintech defined fraud prevention as the purpose and delegated execution to the provider. The provider's use of a sub-contractor does not transfer controller status — it extends the processor relationship through a sub-processing arrangement. The fintech must respond to the data subject's access request for all personal data processed on its behalf, including data held by the sub-contractor.

C. Incorrect — the fintech and the provider are joint controllers for fraud scoring because both benefit from the output of processing.

→ Incorrect. Joint controller status arises when two entities jointly determine the purposes and means of processing — both must be involved in the decision about why and how data is processed. A customer receiving fraud scoring output from a provider that operates the system under contract is not a joint controller relationship; it is a controller-processor relationship.

D. The fintech has no obligation to respond to the access request because the personal data is held by the cloud provider and its sub-contractor, not by the fintech directly.

→ Incorrect. The controller's obligation to respond to data subject requests applies to all personal data processed on the controller's behalf, regardless of which processor or sub-processor holds it physically. The fintech must either retrieve the data from the provider or

direct the provider to respond — the physical location of the data does not extinguish the controller's GDPR obligations.

Question 3 (Scenario-Based)

Scenario: During a vendor assessment, a security team reviews a cloud provider's current documentation. The provider offers: (a) a SOC 2 Type I report dated eight months ago; (b) a SOC 3 report dated six months ago; (c) an ISO/IEC 27001 certificate valid for another fourteen months; and (d) a gap analysis against NIST CSF completed four months ago. The company needs to demonstrate to its external financial auditors that controls over its financial reporting systems hosted by the provider are operating effectively. Which document should the security team request from the provider?

A. The SOC 2 Type I report, because it is the most recent SOC report available and demonstrates control design.

→ Incorrect. A SOC 2 Type I report demonstrates that controls were suitably designed at a specific point in time. It does not demonstrate operating effectiveness over a period. Additionally, SOC 2 assesses the Trust Services Criteria, not financial reporting controls. For SOX-relevant financial reporting assurance, SOC 1 is the required report type.

B. The ISO/IEC 27001 certificate, because it is a current, internationally recognised security standard.

→ Incorrect. ISO/IEC 27001 certification demonstrates that the provider maintains an information security management system meeting the standard's requirements. It does not assess controls specifically relevant to financial reporting and does not satisfy the SOX evidence requirement that external auditors need.

C. A current SOC 1 Type II report, covering a period that includes the organisation's fiscal year, because it assesses controls relevant to financial reporting and demonstrates operating effectiveness over a period.

→ Correct. SOX compliance requires evidence that controls over financial reporting systems are operating effectively, not merely well-designed. A SOC 1 Type II report is the appropriate instrument: it assesses internal controls over financial reporting (ICFR) relevant to user organisations and covers operating effectiveness over a defined period, which is what external financial auditors need. The security team should request a current SOC 1 Type II report from the provider if one is available.

D. The gap analysis against NIST CSF, because it provides the most recent and detailed assessment of control gaps.

→ Incorrect. A gap analysis identifies the difference between current controls and a target framework. It is a planning tool, not an assurance opinion. External auditors require an independent assessment of control effectiveness, not an internal assessment of control gaps. A gap analysis is not audit evidence of control operating effectiveness.

Question 4

Which contract document is the appropriate vehicle for defining a cloud provider's obligation to notify the customer of a security breach within seventy-two hours?

A. The Service Level Agreement, because breach notification is a time-sensitive performance commitment.

→ Incorrect. An SLA defines performance metrics such as uptime and response times for service delivery. Breach notification is a security and compliance obligation, not a service performance metric. Security obligations require a separate contractual vehicle with different remedies and legal implications than SLA credits.

B. The Master Service Agreement, because it governs the overall relationship including security obligations.

→ Incorrect. The MSA covers the general commercial terms of the relationship. While it may reference security obligations at a high level, specific provisions such as breach notification timelines, data processing requirements, and audit rights are typically captured in separate addenda (data processing agreements, security annexes) that form part of the overall contract.

C. The data processing agreement or security annex, which captures specific security obligations, breach notification timelines, and data handling requirements separately from the commercial and performance terms.

→ Correct. Security obligations — including breach notification timelines — belong in the data processing agreement (required under GDPR Article 28) or an equivalent security annex. These documents capture the specific actions the provider must take in security-relevant situations, with legal remedies appropriate to security failures rather than performance credits.

D. The right-to-audit clause, because audit rights allow the customer to discover breaches within the specified timeframe.

→ Incorrect. The right-to-audit clause gives the customer access to review provider controls — it is a verification mechanism, not a notification mechanism. An audit right does not obligate the provider to proactively notify the customer of incidents; it gives the customer the ability to investigate when concerns arise.

Question 5

A CCSP exam question describes an organisation that has a current SOC 2 Type II report from its cloud provider but cannot determine which specific sub-processors the provider used to

handle its data during the assessment period. Which provision of a well-drafted data processing agreement would have addressed this gap?

A. The right-to-audit clause requiring annual review of provider controls.

→ Incorrect. The right-to-audit clause allows the customer to review provider controls on a scheduled basis. It may or may not surface sub-processor information depending on how it is scoped. The specific gap — failure to disclose sub-processors — is addressed by the sub-processor notification provision, not the audit clause.

B. The SLA defining uptime and performance commitments for all processing activities.

→ Incorrect. An SLA covers performance metrics, not the identity of sub-processors or their security obligations. Sub-processor transparency is a data governance requirement, not a performance metric.

C. The sub-processor notification and disclosure provision, requiring the provider to maintain and share a current list of sub-processors and to notify the customer of changes.

→ Correct. A well-drafted data processing agreement, informed by GDPR Article 28 requirements, should require the provider to maintain a current list of sub-processors, make that list available to the customer, and provide advance notice of intended changes. Without this provision, the customer has no visibility into which third parties handle its data as part of the provider's service delivery. A SOC 2 report may include some sub-processor information in the system description, but it is not designed to provide real-time or comprehensive sub-processor disclosure.

D. The data classification schedule defining which categories of data may be processed under the agreement.

→ Incorrect. A data classification schedule defines the types of data the provider may process — it is a scope control. It does not require the provider to disclose which entities perform that processing on the provider's behalf.

Question 6

FERPA differs from GDPR in which significant way that CCSP exam candidates must understand?

A. FERPA applies globally to any institution that holds student data, while GDPR applies only to EU-based organisations.

→ Incorrect. Both statements are backwards. FERPA applies to US educational institutions that receive federal funding — it is geographically and sector-specific. GDPR applies to any organisation processing EU residents' personal data regardless of where the organisation is located — it has global reach based on the data subject's location.

B. FERPA is primarily a data access and disclosure framework that restricts who may access student records and requires consent for disclosure; it does not mandate specific technical security controls in the way that GDPR does.

→ Correct. FERPA's core requirements are about access rights and disclosure restrictions — parents and eligible students may access records, and the institution must obtain consent before disclosing records to third parties. FERPA does not prescribe specific technical security measures. GDPR, by contrast, requires appropriate technical and organisational measures to protect personal data and gives data subjects rights including erasure and portability that go beyond what FERPA provides.

C. FERPA provides a right to erasure equivalent to GDPR Article 17, allowing students to demand deletion of records.

→ Incorrect. FERPA provides a right to access and correct records — students may request that inaccurate records be amended. It does not provide a general right to demand deletion of educational records, which are typically retained by institutions for legal and administrative purposes. GDPR's right to erasure is broader and applies in different circumstances.

D. FERPA imposes fines for non-compliance identical to GDPR's maximum penalty of 4% of global annual turnover.

→ Incorrect. FERPA's primary enforcement mechanism is withdrawal of federal funding from non-compliant institutions, not financial fines. GDPR's fine structure (up to 4% of global annual turnover for serious violations) is a distinctly European enforcement approach with no FERPA equivalent.

Question 7

Which statement correctly describes the relationship between the data custodian role and the processor role in a cloud context?

A. The data custodian and processor are interchangeable terms for the cloud provider's data handling function.

→ Incorrect. These are distinct roles with different functions. Treating them as interchangeable is the specific exam trap that Domain 6 tests. The distinction affects which contractual obligations apply and who must sign what agreements.

B. A data custodian stores and safeguards data without determining processing purpose, while a processor actively handles data to deliver a defined business function on behalf of the controller; only the processor relationship requires a data processing agreement under GDPR.

→ Correct. The custodian-processor distinction is one of the most frequently tested nuances in Domain 6. A cloud backup service that receives encrypted data and stores it without

examining or transforming it acts as a custodian. A cloud analytics provider that ingests data to generate business intelligence is a processor — it handles data as part of active service delivery. GDPR Article 28 requires a data processing agreement for processor relationships; the custodian role does not carry the same GDPR-specific contractual requirements.

C. The processor has legal accountability for data subject rights requests; the custodian does not.

→ Incorrect. Legal accountability for data subject rights requests rests with the controller, not the processor. The processor handles data on controller instructions and may assist the controller in responding to requests, but accountability remains with the controller.

D. The data custodian role is only relevant in on-premises environments; cloud providers always act as processors.

→ Incorrect. Cloud providers can act as custodians, processors, or even controllers depending on the nature of the service and the contractual relationship. A cloud provider operating a storage bucket that the customer uses for backups is more analogous to a custodian than to a processor.

Question 8

An organisation's external legal counsel reviews its cloud contracts and identifies a clause in the SLA stating: 'The provider guarantees 99.9% availability of customer data and will implement industry-standard security measures.' Counsel advises this clause is insufficient from a security governance perspective. Which limitation does counsel most likely have in mind?

A. Industry-standard security measures are not legally enforceable and should be replaced with specific framework certifications.

→ Partially relevant but not the primary limitation counsel is identifying. Vague standards language is problematic, but the more fundamental issue is that placing security obligations in the SLA rather than in dedicated security provisions is structurally incorrect.

B. Availability guarantees and security measures belong in separate documents: SLA provisions address performance, while security obligations require dedicated provisions in a data processing agreement or security annex with appropriate remedies and audit rights.

→ Correct. The structural problem is conflating performance commitments (SLA) with security obligations (data processing agreement or security annex). An SLA's remedies — typically service credits or termination rights — are not appropriate responses to security failures. Security obligations require breach notification timelines, audit rights, sub-processor restrictions, and liability provisions that belong in a dedicated security instrument.

C. The 99.9% availability guarantee is too low for regulated data; the SLA should require 99.99% availability to satisfy compliance requirements.

→ Incorrect. The availability threshold is an operational decision, not the security governance gap counsel is concerned about. Even a 99.99% availability commitment in an SLA would not resolve the structural problem of placing security obligations in a performance document.

D. The SLA should also include breach notification timelines, which would make the security obligation enforceable.

→ Incorrect. Adding breach notification to an SLA does not resolve the structural problem — it adds a security obligation to a document designed for performance governance. The remedy structure, audit mechanisms, and legal treatment of security failures differ materially from those appropriate to performance commitments. Security provisions should be in a dedicated instrument.

Question 9

Which of the following best describes what SOC 2 Type II demonstrates that SOC 2 Type I does not?

A. SOC 2 Type II covers all five Trust Services Criteria; SOC 2 Type I covers only the Security criterion.

→ Incorrect. Both Type I and Type II reports can cover any or all of the five Trust Services Criteria. The criteria covered are a matter of the scope of the engagement, not the type designation. The distinction between Type I and Type II is about point-in-time versus period-of-time assessment.

B. SOC 2 Type II demonstrates that specified controls were operating effectively over a defined period; SOC 2 Type I demonstrates only that controls were suitably designed at a specific point in time.

→ Correct. This is the core distinction. A Type I report is a snapshot: it assesses whether controls were properly designed as of a given date. A Type II report covers a defined period (typically six to twelve months) and assesses whether those controls were operating effectively throughout that period. For ongoing security assurance, Type II is significantly stronger evidence because it demonstrates sustained operation, not just design intent.

C. SOC 2 Type II is issued by a different standard-setting body than SOC 2 Type I.

→ Incorrect. Both Type I and Type II reports are issued under the same professional standard (SSAE 18 in the United States). The distinction is in the nature of the assessment and the period covered, not in the governing standard.

D. SOC 2 Type II includes a gap analysis; SOC 2 Type I does not.

→ Incorrect. Neither SOC 2 Type I nor Type II includes a gap analysis. A gap analysis is a separate pre-certification assessment. SOC reports are independent auditor opinions on control design or operating effectiveness, not assessments of control gaps.

Question 10

A CCSP candidate reads the following exam scenario: 'An organisation migrated its entire HR and payroll processing function to a cloud provider. Six months later, a regulatory investigation reveals the organisation failed to implement required data retention controls. The cloud provider argues it is not responsible because it only provided infrastructure services.' Which principle should the candidate apply to identify the correct answer?

A. The cloud provider is solely responsible because it operated the infrastructure on which the retention failure occurred.

→ Incorrect. The provider's operation of infrastructure does not transfer accountability for compliance with data retention requirements to the provider. The customer retains legal accountability as the data controller or as the entity regulated under the applicable framework. The exam will never select an answer that assigns sole responsibility to a provider for a customer's compliance failure.

B. The organisation retains legal accountability for compliance because cloud migration transfers operational tasks but does not transfer legal obligations; the organisation should have implemented or contractually required appropriate retention controls.

→ Correct. This is the governing principle of Domain 6. The organisation is accountable for the regulatory requirement (data retention) regardless of where the data resides or which party operates the infrastructure. In a cloud environment, the organisation must either implement the required controls directly (using cloud-native tools) or contractually require the provider to implement them. Failing to do either is the organisation's compliance failure, not the provider's.

C. Responsibility is shared equally between the organisation and the provider under the cloud shared responsibility model.

→ Incorrect. The shared responsibility model defines which technical controls each party is responsible for implementing, but it does not divide legal accountability for regulatory compliance equally. Regulatory obligations follow the regulated entity, not the technical architecture. The organisation cannot point to a shared responsibility model to halve its regulatory liability.

D. The regulatory investigation was improper because cloud environments are governed by the cloud provider's jurisdiction, not the customer's.

→ Incorrect. Regulatory jurisdiction follows the regulated entity and the data subject, not the location of the cloud infrastructure. An organisation regulated under a specific framework

remains subject to that framework's requirements regardless of which cloud provider it uses or where that provider's data centres are located.